14.5 Regulatory compliance and authorization

The same structures that align identity and authorization can also be used to fulfill external obligations. Compliance and authorization are closely related. Every regulation that guides how organizations handle information—whether privacy laws, financial reporting rules, or cybersecurity standards—ultimately depends on defining who can do what, when, and under what conditions. Policy governance provides the framework that turns those legal and procedural requirements into practical authorization logic.

At ACME, the compliance team initially viewed authorization as an operational detail—a matter of engineering practice rather than governance oversight. That changed when auditors began asking for not only proof that access controls existed but also evidence showing how those controls were governed. They wanted to see decision histories, approval workflows, and documentation linking policy changes to regulatory requirements. The company realized that compliance could no longer be demonstrated through spreadsheets and attestations alone; it needed to be built directly into the authorization system.

Governance offers that bridge. Regulations like GDPR, HIPAA, SOX, and PCI-DSS all impose requirements that map naturally to authorization policy elements:

- GDPR’s data minimization and purpose-limitation principles relate to policies that restrict access to personal data based on role, relationship, or purpose.
- HIPAA’s requirement for least privilege maps to conditional policies that restrict medical record access to treatment or operations contexts.
- SOX and PCI-DSS require audit trails and access reviews, which governance supplies through version control, decision logs, and policy review schedules.

Through the Access Control Coordinating Council, ACME connects its compliance obligations to the policies and architecture decisions that carry them out. Instead of creating separate ADRs for each regulation, policy authors include references to relevant regulatory controls within the ADRs to